情報処理安全確保支援士試験　科目A-2　中分類23 情報セキュリティの脅威　#01

# 脅威と脆弱性

だれが、どこから、何を使って、なぜ攻めてくるのか

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案・10大脅威・内部不正防止ガイドライン、OWASP、MITRE CWE など）を書いた。過去問は IPA 公開の午前 II 。例の会社や場面は Claude が作った

# 全体像 シラバス案 中分類23 小分類1「脅威と脆弱性」の4項目

**1 脅威の種類と動向**
攻撃ベクトル・攻撃対象領域・脅威モデリング（STRIDE）・BEC・10大脅威

**2 マルウェア・不正プログラム**
RAT・リバースシェル・ランサムウェア・ステルス技術・ファイルレス・エクスプロイトコード

**3 脆弱性**
認可の不備・入力確認・ハードコード・認証バイパス・平文・レースコンディション・OWASP の3つの Top 10

**4 不正の動機・メカニズム**
不正のトライアングル・ハクティビズム・RaaS・IAB・二重恐喝・ダークウェブ

| 支援士の新制度（2027年度〜） | 中身 |
|---|---|
| 科目A-1（共通知識） | 45分・30問 |
| 科目A-2（専門知識）← この教材 | 35分・25問 |
| 科目B（技能） | 120分・12問（選択式） |

**午前 II との関係：**IPA は、科目Aの出題範囲は「表記の変更等で、範囲そのものに変更はない」としている。だから過去の午前 II がそのまま練習になる。

**この分野の過去問の傾向：**マルウェアの名前と動作（Mirai・クリプトジャッキング・ルートキット・コネクトバック）を、似た説明と見分けさせる問題が多い。

出典：IPA「情報処理安全確保支援士試験 シラバス（案）Ver.0.1」／IPA「情報処理技術者試験及び情報処理安全確保支援士試験の見直しの検討状況について」

第1章

# 脅威の種類と動向

攻撃の「入口」と「種類」を整理する。設計の段階で脅威を洗い出すのが脅威モデリング。

# 攻撃ベクトルと攻撃対象領域:「道」と「入口の総和」




**攻撃ベクトル:**「どこから・何を使って」入るかという個々の経路。CVSS の基本評価基準にも「攻撃元区分(AV)」として出てくる(ネットワーク・隣接・ローカル・物理)。

**攻撃対象領域の最小化:**使わないサービスを止め、公開範囲を絞り、不要なアカウントを消す。外部から見える資産を継続的に把握するのが ASM／EASM(#12)。

出典:IPA「支援士試験 シラバス(案)」中分類23 小分類1 用語例「攻撃ベクトル, 攻撃対象領域(アタックサーフェス)」、中分類24 小分類1「攻撃対象領域の最小化」、中分類25 小分類5「ASM／EASM」

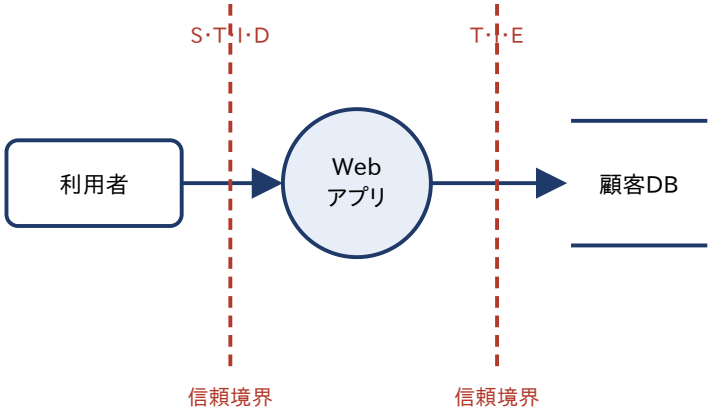
# STRIDE：脅威の6種類は「守りたい性質」の裏返し

| STRIDE | 損なわれる性質 | 例 | 主な対策 |
|---|---|---|---|
| **S なりすまし**<br>Spoofing | **真正性（認証）** | 盗んだパスワードで他人としてログインする | 多要素認証・パスキー |
| **T 改ざん**<br>Tampering | **完全性** | 通信途中や DB の金額を書き換える | MAC・デジタル署名・アクセス制御 |
| **R 否認**<br>Repudiation | **否認防止** | 「その注文は自分ではない」と言い逃れる | デジタル署名・改ざんできないログ |
| **I 情報漏えい**<br>Information disclosure | **機密性** | エラーメッセージに内部情報が出る | 暗号化・最小権限 |
| **D サービス妨害**<br>Denial of service | **可用性** | 大量のリクエストでサービスを止める | レート制限・冗長化・CDN |
| **E 権限昇格**<br>Elevation of privilege | **認可** | 一般利用者が管理者の操作を行う | サーバ側での認可の確認 |

**区別：**STRIDE は脅威の**種類**の分け方。サイバーキルチェーンや MITRE ATT&CK は攻撃の**段階・手口**の分け方（#02）。問題文が「設計時に脅威を網羅的に洗い出す」なら STRIDE。

出典：Microsoft「Threat Modeling Tool の脅威」（STRIDE の6分類）／IPA「支援士試験 シラバス（案）」用語例「脅威モデリング（STRIDE など）」

# 脅威モデリングの進め方：作る前に脅威を洗い出す




データフロー図（DFD）。境界をまたぐ流れが、脅威を当てはめる場所。図は Claude が作った例。

1. **図にする：**データの流れ・保存場所・外部の相手・信頼境界を DFD に描く
2. **洗い出す：**境界をまたぐ流れと要素ごとに STRIDE を当てはめる
3. **評価する：**起こりやすさと影響で優先順位を付ける（リスク評価は #06）
4. **対策を決める：**要件に落とし込む（認証・暗号化・入力検証・ログなど）
5. **確かめる：**実装後のレビューやテストで、対策が効いているかを検証する

> **セキュリティ・バイ・デザイン：**脆弱性は作ったあとで直すほど費用がかかる。だから要件定義・設計の段階で脅威モデリングを行う。科目Bでも「設計書を読んで不足している対策を指摘する」形で問われる。

出典：IPA「支援士試験 シラバス（案）」中分類23 用語例「脅威モデリング」「脅威シナリオ」、中分類24 小分類1「セキュリティ・バイ・デザイン」、目標とする技能 2-1「脅威分析の結果からセキュリティ要件を定義する能力」

# 情報セキュリティ10大脅威 2026［組織］

| 順位 | 脅威 | 初選出 |
|---|---|---|
| 1 | ランサム攻撃による被害 | 2016年（11年連続） |
| 2 | サプライチェーンや委託先を狙った攻撃 | 2019年 |
| 3 | **AIの利用をめぐるサイバーリスク** | **2026年 初選出** |
| 4 | システムの脆弱性を悪用した攻撃 | 2016年 |
| 5 | 機密情報を狙った標的型攻撃 | 2016年 |
| 6 | 地政学的リスクに起因するサイバー攻撃（情報戦を含む） | 2025年 |
| 7 | 内部不正による情報漏えい等 | 2016年 |
| 8 | リモートワーク等の環境や仕組みを狙った攻撃 | 2021年 |
| 9 | DDoS攻撃（分散型サービス妨害攻撃） | 2016年 |
| 10 | ビジネスメール詐欺 | 2018年 |

出典：IPA「情報セキュリティ10大脅威 2026」（「組織」向け脅威の表）

**この教材のどこで扱うか**

| 脅威 | 分野 |
|---|---|
| ランサム・内部不正・BEC | #01 |
| 標的型攻撃・リモートワーク | #02・#13 |
| DDoS | #04 |
| AI・サプライチェーン | #05・#18 |
| 脆弱性の悪用 | #12・#19 |

> 順位を覚えるより、**それぞれの手口と対策**を説明できることが大事。

# 人をだます脅威：BEC・ソーシャルエンジニアリング・踏み台

**ビジネスメール詐欺（BEC）の典型的な流れ**

**① 侵入・盗み見**
取引先や自社のメールアカウントを乗っ取る

→

**② 観察**
請求のタイミングや文面のくせを学ぶ

→

**③ なりすまし**
似たドメインや乗っ取った本物のアカウントから送る

→

**④ 送金**
「口座が変わった」と攻撃者の口座へ

| 手口 | 中身 |
|---|---|
| **ソーシャルエンジニアリング** | 権威・緊急性・親切心につけこむ。電話、のぞき見（ショルダーハッキング）、ごみあさり（トラッシング） |
| **踏み台** | 乗っ取った機器を中継に使い、攻撃元を隠す。弱い子会社から親会社へ、など |
| **アクセス権の誤設定** | 攻撃がなくても漏えいする。クラウドの公開設定ミスが典型 |

**BEC の対策：**マルウェアを使わないことが多いので、技術だけでは防げない。**振込先の変更はメール以外の、前から知っている連絡先で確かめる**手順を決める。送信ドメイン認証（SPF・DKIM・DMARC、#14）で、なりすましドメインを減らす。

**ひっかけ：**「定義ファイルの更新」「添付の拡張子の確認」は、添付もマルウェアもない BEC には効かない。

出典：IPA「情報セキュリティ10大脅威 2026」10位 ビジネスメール詐欺／IPA「支援士試験 シラバス（案）」用語例「ビジネスメール詐欺（BEC）, アクセス権の誤設定, ソーシャルエンジニアリング, 踏み台」

第2章

# マルウェア・不正プログラム

何をするか（目的）と、どう隠れるか（ステルス技術）の2つの軸で整理する。

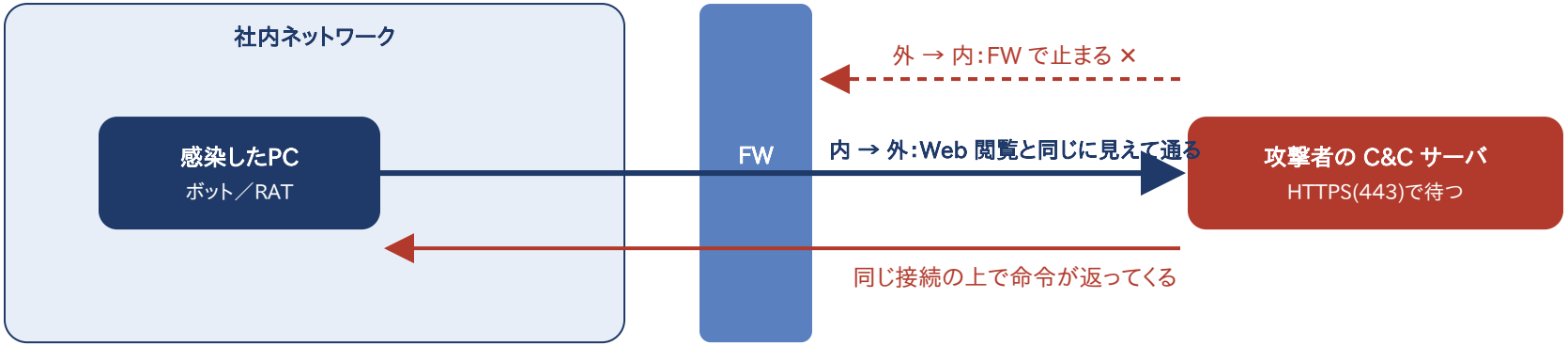
# マルウェアを「何をするか」で分ける

| 目的 | 名前 | 動作 | 見分けるキーワード |
|---|---|---|---|
| 遠隔操作 | ボット／C&C サーバ | C&C サーバの指令で DDoS・スパム・感染拡大 | 指令・ボットネット |
| | RAT | 感染した PC を攻撃者が遠隔から自由に操作 | 遠隔操作型ウイルス |
| | リバースシェル | 内側から攻撃者へ接続してシェルを渡す | コネクトバック |
| 金銭 | ランサムウェア | 暗号化・ロックして身代金を要求 | 暗号化・脅迫 |
| | クリプトジャッキング | 他人の計算資源で暗号資産をマイニング | マイニング・CPU |
| 潜伏 | ルートキット | 侵入の痕跡・ツールを隠す | 隠ぺい |
| | バックドア | 認証を通らずに再び入れる裏口 | 永続化 |
| 侵入の道具 | エクスプロイトコード | 脆弱性を悪用するコード（検証にも使う） | 攻撃コード |
| | エクスプロイトキット | 複数の攻撃コードと管理機能をまとめた道具箱 | 専門知識なしで攻撃 |

**過去問の作り：**名前を1つ出し、ほかの3つの選択肢には「別のマルウェアの説明」を並べる。この表の右端の言葉で見分ける。

出典：IPA「支援士試験 シラバス（案）」中分類23 小分類1 用語例（マルウェア・不正プログラム）／IPA 午前 II 令和7年度春期 問5・問7・問8、令和3年度秋期 問14、令和元年度秋期 問15

# C&C とコネクトバック：なぜ「内から外」が危ないか




**コネクトバック**＝侵害したシステムから攻撃者のサーバへ通信を始めること（令和7年度春期 問8）。リバースシェルやボットの C&C 通信がこの形。

**対策：**出口（外向き通信）を絞る。プロキシ経由だけを許し、認証を求める。宛先の評判（脅威インテリジェンス、#09）で不審な通信先を止め、ログで定期的な通信（ビーコン）を探す。

出典：IPA 午前 II 令和7年度春期 問8（コネクトバック）／IPA「支援士試験 シラバス（案）」中分類23 用語例「リバースシェル」「C2（Command and Control）」

# ステルス技術：見つからないための工夫

| 技術 | 何が変わる・何が残らない | 対抗する検知 |
|---|---|---|
| **ポリモーフィック型** | 感染のたびに**暗号化の鍵や復号部**を変える。復号後の本体は同じ | ビヘイビア法（振る舞い）、メモリ上での検査 |
| **メタモーフィック型** | 感染のたびに**本体のコードそのもの**を書き換える（命令の並べ替え、無意味な命令の挿入） | ビヘイビア法、ヒューリスティック法 |
| **ファイルレス** | 実行ファイルをディスクに**残さず**、PowerShell・WMI など正規ツールでメモリ上だけで動く | EDR、PowerShell のログ、メモリフォレンジック |
| **ルートキット** | 侵入後のツールやプロセス・ログを**隠す**（OS のカーネルやコマンドを改変） | 別の起動媒体からの検査、OS の再インストール |
| **パッカー・難読化** | 圧縮や暗号化でコードを読みにくくし、静的解析を妨げる | アンパックしてから解析（#19） |

**パターンマッチング**（定義ファイルと照合）は、見た目が変わる・ファイルがない相手に弱い。だから振る舞いで見る方式（#12）と組み合わせる。

**ひっかけ：**「メモリ上だけで動く」はファイルレス、「痕跡を隠す」はルートキット。ポリモーフィックとメタモーフィックの違いは「本体まで変えるか」。

出典：IPA「支援士試験 シラバス（案）」中分類23 用語例「ステルス技術（ポリモーフィック型，メタモーフィック型 など），ファイルレスマルウェア」、中分類26 小分類2「解析やセキュリティ検知を回避する技術（パッカー，難読化…）」

# いまのランサムウェア攻撃：侵入してから暗号化する

**① 侵入**
VPN 機器の脆弱性・盗んだ認証情報（IAB から購入）

→

**② 権限昇格・横展開**
管理者権限を奪い、AD やサーバに広がる

→

**③ 持ち出し**
機密データを外部へ送る

→

**④ 妨害**
バックアップを消す・セキュリティ製品を止める

→

**⑤ 暗号化と脅迫**
復号と非公開の両方で身代金

| 段階 | 止める対策の例 |
|---|---|
| ① | VPN 機器のパッチ、多要素認証、公開範囲の最小化 |
| ② | 特権アカウントの管理（PAM）、ネットワークの分離、EDR |
| ③ | 外向き通信の監視、DLP |
| ④⑤ | オフライン・イミュータブルなバックアップ、3-2-1 ルール（#12）、復旧手順の訓練 |

**二重恐喝：**③で盗んでいるので、バックアップから戻せても「公開する」という脅しは残る。

**クリプトジャッキングとの違い：**あちらはデータを壊さず、計算資源だけを盗む（令和7年度春期 問5）。

出典：IPA「情報セキュリティ10大脅威 2026」1位 ランサム攻撃による被害／IPA「支援士試験 シラバス（案）」中分類25 小分類5〔ランサムウェア対策〕（バックアップ分離，3-2-1 ルール，イミュータブルバックアップ など）

# Mirai：初期パスワードの IoT 機器をボットにする

1. **探す：**ランダムな宛先 IP アドレスに、Telnet（TCP 23番など）で接続を試みる
2. **ログインする：**よくある初期設定の ID・パスワードの一覧を順に試す
3. **感染する：**ログインできた機器に本体を送り込み、ボットにする
4. **増える：**感染した機器がさらに①から繰り返す
5. **攻撃する：**C&C サーバの指令で、標的に一斉に DDoS 攻撃

**午前 II の選択肢の見分け方（令和7年度春期 問7）**

| 選択肢の特徴 | 判定 |
|---|---|
| ランダムな宛先・C&C の指令で DDoS | Mirai |
| Web サーバの脆弱性・決められた日時に DDoS | 別物 |
| Web ページに JavaScript を挿入して誘導 | 改ざん |
| ファイル共有ソフトで情報を公開 | 暴露ウイルス |

**対策：**初期パスワードの変更、Telnet など不要なポートを閉じる、ファームウェアの更新。総務省・NICT の NOTICE（#07）は、こうした機器を調べて注意喚起する取組。

出典：IPA 午前 II 令和7年度春期 問7（令和5年度秋期 問6）・令和3年度秋期 問11（TCP 23番への攻撃）

第3章

# 脆弱性

作り方の不備（技術）と、人・組織の不備。どれも CWE や OWASP の分類で名前が付いている。

# シラバス案に並ぶ脆弱性と、その正体

| 脆弱性 | どんな不備か | CWE | 根本的な対策 |
|---|---|---|---|
| **認可・アクセス制御の不備** | ログイン後に他人のデータや管理機能に手が届く（IDの書き換え＝IDOR） | CWE-862 ほか | 要求のたびにサーバ側で権限を確認 |
| **認証バイパス** | 認証そのものを経ずに機能に到達できる | CWE-306 | すべての入口で認証を確認 |
| **不適切な入力確認** | 想定外の入力をそのまま処理に使う | CWE-20 | 入力検証＋出力先に合わせたエスケープ |
| **パスワードのハードコード** | 認証情報をコードに書き込む。全製品で共通・変更不可になりがち | CWE-798 | シークレットストアで管理 |
| **平文での保存・送信** | 重要情報を暗号化せずに保存・通信する | CWE-312／319 | TLS、保存時の暗号化、パスワードはハッシュ |
| **レースコンディション** | 処理の順序やタイミングのずれをつかれる | CWE-362／367 | 確認と使用を不可分にする |

**認証と認可：**認証＝「あなたはだれか」、認可＝「あなたはそれをしてよいか」。ログインしているのに他人の注文が見えるのは**認可**の不備。ログイン画面を飛ばせるのは**認証**バイパス。

出典：IPA「支援士試験 シラバス（案）」中分類23 小分類1 用語例（脆弱性）／MITRE「CWE」（CWE-20・306・312・319・362・367・798・862）

# レースコンディション（TOCTOU）：確認と使用のすきま




**TOCTOU**（Time of Check to Time of Use）＝確認した時点と使う時点のずれ。間に対象を差し替えられると、確認の意味がなくなる。

**Web での例：**クーポンの「使用済みか確認」と「使用済みにする」の間に同じ要求を同時に大量に送り、何度も使う。対策は DB のトランザクションやロックで、確認と更新を1つの不可分な処理にする（#21）。

出典：MITRE「CWE-367 Time-of-check Time-of-use (TOCTOU) Race Condition」／IPA「支援士試験 シラバス（案）」用語例「レースコンディション」。図は Claude が作った例

# OWASP の3つの Top 10

| Top 10:2025（Web アプリ） | |
|---|---|
| A01 | **アクセス制御の不備** |
| A02 | セキュリティ設定のミス |
| A03 | ソフトウェアサプライチェーンの不備 |
| A04 | 暗号化の失敗 |
| A05 | インジェクション |
| A06 | 安全でない設計 |
| A07 | 認証の不備 |
| A08 | ソフトウェアとデータの完全性の不備 |
| A09 | ログとアラートの不備 |
| A10 | 例外的な状況の不適切な処理 |

| LLM Applications 2025 | |
|---|---|
| 01 | **プロンプトインジェクション** |
| 02 | 機密情報の漏えい |
| 03 | サプライチェーン |
| 04 | データとモデルのポイズニング |
| 05 | 不適切な出力の処理 |
| 06 | 過剰な権限（エージェンシー） |
| 07 | システムプロンプトの漏えい |
| 08 | ベクトルと埋め込みの弱点 |
| 09 | 誤情報 |
| 10 | 際限のない資源の消費 |

| API Security 2023 | |
|---|---|
| 1 | **オブジェクトレベルの認可の不備（BOLA）** |
| 2 | 認証の不備 |
| 3 | プロパティレベルの認可の不備 |
| 4 | 際限のない資源の消費 |
| 5 | 機能レベルの認可の不備 |
| 6 | 重要な業務フローへの無制限のアクセス |
| 7 | SSRF |
| 8 | セキュリティ設定のミス |
| 9 | 不適切なインベントリ管理 |
| 10 | 安全でない API の利用 |

**共通点：**Web も API も1位は**認可の不備**。LLM の1位はプロンプトインジェクション（攻撃は #05、対策は #18）。日本語は Claude の訳。

出典：OWASP Top 10:2025／OWASP Top 10 for LLM Applications 2025／OWASP API Security Top 10 2023

# 人と組織の脆弱性

**人的脆弱性**

不注意・知識不足・心理的な弱さ。添付を確認せず開く、パスワードを付箋に書く。

**対策:** 教育・訓練（標的型メール訓練、#09）、一人の判断に頼らない手順

**シャドーIT**

情報システム部門が把握していないクラウドや機器を業務に使う。生成 AI への機密の入力も。

**対策:** CASB で見える化（#13）、使ってよいサービスと規程を用意（#08）

**内部統制の不備**

職務の分離・承認・ログの確認がない。一人で申請も承認もできる。

**対策:** 職務の分離、アクセス権の定期的な見直し、ログの監視

**なぜ「脆弱性」に入っているか:** リスクは「脅威が脆弱性につけこんで資産に損害を与える可能性」。技術の穴をふさいでも、人と組織の穴が残れば同じように攻撃される。支援士は技術だけでなく、規程・教育・体制の指導・助言も役割（科目Bの技能 1-8 人的管理）。

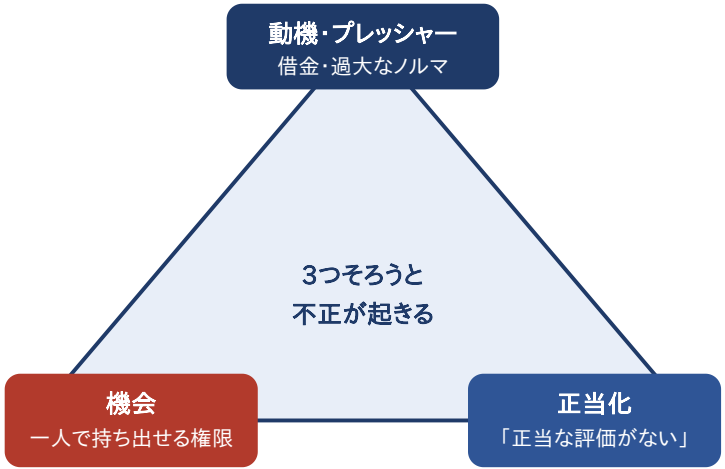
出典：IPA「支援士試験 シラバス（案）」中分類23 用語例「人的脆弱性, 内部統制の不備, シャドーIT」、目標とする技能 1-8「人的管理」

第4章

# 不正の動機とメカニズム

内部の人はなぜ不正をするのか。外部の攻撃者はどう分業し、どこで稼ぐのか。

# 不正のトライアングルと内部不正防止の5原則



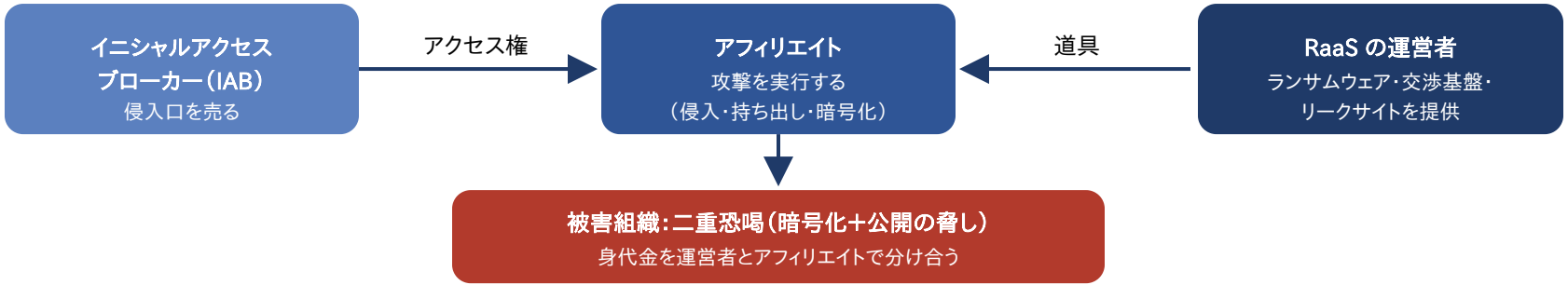

IPA「組織における内部不正防止ガイドライン」の5つの基本原則（状況的犯罪予防）

| 原則 | 対策の例 |
|---|---|
| 犯行を難しくする | アクセス権の最小化、職務の分離 |
| 捕まるリスクを高める | ログの取得と監視、その周知 |
| 犯行の見返りを減らす | データの暗号化、持ち出しても使えなくする |
| 犯行の誘因を減らす | 公平な評価、職場環境の改善 |
| 犯罪の弁明をさせない | ルールの周知、誓約書 |

> 組織が直接減らしやすいのは**機会**。

出典：IPA「組織における内部不正防止ガイドライン」／IPA「支援士試験 シラバス（案）」用語例「不正のトライアングル」、中分類25 小分類2「組織における内部不正防止ガイドライン」

# 攻撃者の分業：IAB・RaaS・二重恐喝




| 用語 | ひとことで |
|---|---|
| ダークウェブ | Tor などでしか見られない匿名のサイト。侵入口・盗んだ情報の売買、リークサイト |
| ハクティビズム | 金銭でなく、政治的・社会的な主張のための攻撃（改ざん・DDoS） |
| 多重恐喝 | 二重恐喝に、DDoS や顧客・取引先への連絡を加える |

**なぜ被害が増えたか：**分業によって、高い技術がなくても攻撃に加われるようになった。防御側は「侵入口（認証情報・VPN）」「持ち出し（外向き通信）」「復旧（バックアップ）」のそれぞれで手を打つ。

出典：IPA「支援士試験 シラバス（案）」用語例「ダークウェブ，ハクティビズム，RaaS，イニシャルアクセスブローカー，二重恐喝（多重恐喝）」／IPA「情報セキュリティ10大脅威 2026」

# 試験で狙われやすい比較10選

| 比べるもの | 見分けるポイント |
|---|---|
| **攻撃ベクトル ⇔ 攻撃対象領域** | 1本の道 ⇔ 入口の総和（最小化するのはこちら） |
| **STRIDE ⇔ サイバーキルチェーン** | 脅威の種類 ⇔ 攻撃の段階 |
| **BEC ⇔ フィッシング** | 送金させる ⇔ 偽サイトで認証情報を盗む |
| **RAT ⇔ ボット** | 1台を遠隔操作 ⇔ 多数を C&C の指令でまとめて動かす |
| **ランサムウェア ⇔ クリプトジャッキング** | 暗号化して身代金 ⇔ 計算資源でマイニング |
| **ポリモーフィック ⇔ メタモーフィック** | 暗号化の部分だけ変える ⇔ 本体のコードまで変える |
| **ファイルレス ⇔ ルートキット** | ディスクに残さずメモリで動く ⇔ 痕跡を隠す |
| **エクスプロイトコード ⇔ エクスプロイトキット** | 1つの攻撃コード ⇔ 複数の攻撃コード+管理機能の道具箱 |
| **認可の不備 ⇔ 認証バイパス** | ログイン後に権限を超える ⇔ ログインそのものを飛ばす |
| **RaaS ⇔ IAB** | ランサムウェアを貸す ⇔ 侵入口を売る |

次の #02 では、攻撃の流れ（サイバーキルチェーン・MITRE ATT&CK）と、パスワードやセッションをねらう攻撃を扱う。

出典：このPDFの各ページの資料